Análise técnica do projeto Login OAuth

Repositório: Nicaribeiro/login-oauth | Branch examinada: main | 15 de outubro de 2026
Escopo: estrutura, autenticação OAuth, GitHub Actions, migrações Cloudflare D1, evidências e Pull Request.

1. Resumo executivo

O projeto apresenta uma implementação organizada de autenticação com Google e GitHub usando Cloudflare Pages Functions e D1. Na branch **main** foram identificados três workflows YAML, documentação da avaliação, arquivos de migração e evidências de testes. A documentação registra cenários reais de CI, proteção da main, revisão por IA e migração remota. Não foi realizado teste de execução do site, dos segredos ou das configurações da Cloudflare nesta análise.

2. Diagnóstico do Pull Request

- **Comparação verificada:** base **main**, head **adaptacao-github-actions**.
- **Resultado do GitHub:** ahead_by = 0; behind_by = 7; status = behind; nenhuma alteração de arquivo na comparação.
- **Conclusão:** a branch de adaptação está sete commits atrás da main e não traz commits exclusivos. Por isso a criação do PR retornou 422: 'No commits between main and adaptacao-github-actions'.
- **Ação correta:** não abrir PR vazio ou acrescentar mudança fictícia. Se houver trabalho novo, criar uma branch a partir da main atual, realizar uma alteração legítima, commitar e abrir o PR.

3. Estrutura identificada

- **.github/workflows/ci.yml:** CI de validação.
- **.github/workflows/revisao-ia.yml:** revisão automática de pull requests.
- **.github/workflows/migrar.yml:** aplicação de migrações D1 no ambiente remoto.
- **functions/oauth/:** rotas de login, callback e logout; **functions/_shared/:** cookies, criptografia, provedores e OIDC.
- **migrations/:** criação inicial de tabelas e alteração da tabela notas.
- **public/:** interface do site; **evidencias/:** capturas e textos; **AVALIACAO.md:** referências da atividade.

4. GitHub Actions

CI (ci.yml): é acionado por push e por pull_request para main. Busca padrões indicativos de segredos, aplica as migrações em SQLite local e valida HTML com HTMLHint. Pontos positivos: verificações automáticas e permissão geral restrita a contents: read.

Limitação do CI: a busca de segredos usa expressões específicas, não substitui uma ferramenta abrangente de secret scanning; também não executa testes automatizados de ponta a ponta do login OAuth.

Revisão por IA (revisao-ia.yml): aciona em PRs internos destinados à main; monta um diff limitado a 20 mil caracteres, pede atenção a segredos, SQL concatenado e lógica, usa actions/ai-inference e comenta no PR. Mantém contents: read e pull-requests: write. Revisões de IA podem conter erros e não substituem checks.

Migrações (migrar.yml): roda em push na main somente quando há alteração em migrations/**. Verifica segredos Cloudflare, aplica migrações remotas via Wrangler e consulta PRAGMA table_info(notas). Há controle

de concorrência para evitar execuções simultâneas.

Observação: a documentação explica que são três arquivos de workflow, enquanto a proteção da main é uma configuração do próprio GitHub. A verificação atual de regras de proteção pelo conector retornou acesso negado; portanto seu estado presente não foi auditado diretamente.

5. OAuth e acesso ao banco

O código do login gera state, PKCE/code_verifier e cookie temporário; a transação expira em dez minutos. O callback exige code/state, confere transação e hash do state, elimina a transação para evitar reuso e, no Google, valida ID token. No GitHub, consulta o perfil e tenta revogar a autorização após o uso. Sessões usam tokens opacos e valores hash no D1, com duração prevista de oito horas.

Achados favoráveis: as consultas SQL examinadas utilizam prepare().bind(), reduzindo risco de injeção; o fluxo tem verificações de state e utiliza cookies auxiliares. **Limite:** não foram executados login real, testes de cookies no navegador, análise completa de todos os módulos ou ataque controlado.

6. Cloudflare D1

O arquivo wrangler.toml define o binding DB, um banco D1 nomeado e migrations_dir. A segunda migração contém `ALTER TABLE notas ADD COLUMN titulo TEXT;`. O relatório AVALIACAO.md referencia execução remota aprovada e confirmação da coluna titulo por PRAGMA. Esses resultados são evidências **documentadas no repositório**, não uma consulta independente ao banco nesta análise.

7. Evidências da atividade

A árvore do repositório contém arquivos de evidência numerados, incluindo capturas de CI reprovado/aprovado, bloqueio de PR, push recusado, revisão por IA, migração e filtro de paths. AVALIACAO.md também relaciona URLs de runs e PRs e responde perguntas conceituais. Foi verificada a presença dos arquivos e o texto da documentação; as imagens e os logs remotos não foram revalidados individualmente.

8. Pontos de atenção e prioridades

- **Prioridade alta:** não tentar PR da branch adaptacao-github-actions enquanto ela estiver sem commits exclusivos.
- **Prioridade alta:** conferir no GitHub a proteção efetiva de main, checks obrigatórios e permissões de Actions; a leitura automatizada da proteção não foi autorizada.
- **Prioridade alta:** manter os segredos exclusivamente em GitHub Secrets/Cloudflare, sem expô-los em commits ou documentação. Se um token tiver sido divulgado anteriormente, revogá-lo e emitir outro.
- **Prioridade média:** revisar se o workflow de IA segue atendendo às permissões e autenticação exigidas pelo GitHub.
- **Prioridade média:** incluir testes automatizados para rotas OAuth e sessão, além dos testes atuais de HTML/SQL.
- **Prioridade média:** verificar periodicamente migrações aplicadas e consistência do esquema remoto antes de alterações futuras.

9. Conclusão

Pelo conteúdo examinado da main, o projeto está bem encaminhado e possui materiais organizados para a avaliação. O impedimento imediato para abrir o PR solicitado não é uma falha de sintaxe dos workflows: a branch selecionada simplesmente não possui commits novos em relação à main. Os registros de sucesso da atividade são consistentes com a documentação encontrada, mas sua confirmação operacional depende de verificar os

runs, as regras do repositório e o ambiente Cloudflare.

Fontes verificadas

GitHub conectado: metadados do repositório, comparação main...adaptacao-github-actions, árvore de arquivos da main e conteúdo de ci.yml, revisao-ia.yml, migrar.yml, AVALIACAO.md, README.md, wrangler.toml, rotas de login/callback, migração 0002 e índice de evidências.
Repositório: https://github.com/Nicaribeiro/login-oauth